

Cisco Secure Workload - Framework Scope Design Guide

Customer-facing scope and label patterns for Cisco Secure Workload (CSW) compliance mapping workshops.

Use this guide before a proof-of-value, deployment planning workshop, or evidence-readiness discussion. It helps teams translate framework language into practical CSW scopes, labels, and evidence boundaries. These patterns are starting points: validate final scope with the customer's architecture, asset owners, compliance team, and assessor.

Scope Design Principles

1. Start from the protected service, not the tool. Define the system, business function, data boundary, or regulated environment first; then map CSW scopes to that boundary.
2. Separate regulatory scope from operational ownership. A PCI CDE, HIPAA ePHI zone, CUI enclave, or DORA important business function may cross teams, clouds, and platforms.
3. Use labels for policy and evidence. Scopes should be generated from stable labels where possible so inventory, ADM, flow search, policy workspaces, and reports use the same vocabulary.
4. Reconcile CSW coverage. CSW evidence covers instrumented workloads and supported connector visibility. Reconcile gaps with the CMDB, cloud inventory, OT inventory, IAM, SIEM, vulnerability scanner, and GRC tools.
5. Keep out-of-scope explicit. Physical controls, legal obligations, cryptographic module validation, IAM/MFA, endpoint malware controls, and OT device enforcement usually require complementary controls.

Framework Scope Design Table

Table: Framework / Customer scope anchor / Suggested CSW scope pattern / Primary evidence focus / Boundaries and complementary controls

HIPAA Security Rule: Customer scope anchor: ePHI applications, databases, clinical integrations, and business associate connections; Suggested CSW scope pattern: Healthcare-Org > ePHI-Zone > app/service scopes such as EHR, Billing, PACS, HL7; separate BAA-Partners egress scope; Primary evidence focus: ePHI workload isolation, access-path evidence, audit-control telemetry, risk-analysis inputs; Boundaries and complementary controls: HIPAA administrative, physical, legal, and BAA obligations remain outside CSW; validate PHI classification with privacy/compliance owners
SOC 2 Type II: Customer scope anchor: The service organization's system boundary and selected Trust Services Criteria; Suggested CSW scope pattern: SOC2-System > Production, Supporting-Infra, Admin-Access, Vendor-Integrations; align scope to system description; Primary evidence focus: Operating-effectiveness evidence for segmentation, monitoring, change drift, incident investigation; Boundaries and complementary controls: SOC 2 criteria depend on the auditor's system description and control design; CSW augments IAM, change management, SIEM, and availability controls
PCI DSS v4.0: Customer scope anchor: Cardholder Data Environment (CDE), CDE-connected systems, and security-impacting systems; Suggested CSW scope pattern: PCI-Environment > CDE, CDE-Connected, Security-Services, Third-Party-Processors, Out-of-Scope-Validation; Primary evidence focus: CDE flow documentation, segmentation simulation/enforcement, policy exceptions, vulnerability exposure context; Boundaries and complementary controls: CSW does not replace QSA judgment, ASV scans, penetration testing, network security controls, or PCI governance requirements
NIST SP 800-53 Rev. 5: Customer scope anchor: FISMA/FedRAMP system boundary and SSP control implementation; Suggested CSW scope pattern: System-Boundary > impact-level or component scopes such as Moderate, High, Data-Store, App-Tier, Management; Primary evidence focus: AC, AU, CM, IR, RA, SC, and SI evidence for covered workloads; Boundaries and complementary controls: Full 800-53 scope includes many controls outside CSW: identity, personnel, physical, contingency, privacy, and governance controls
ISO/IEC 27001:2022: Customer scope anchor: ISMS scope, information assets, and Annex A control applicability; Suggested CSW scope pattern: ISMS-Boundary > Confidential-Data, Business-Critical-Apps, Cloud-Services, Supplier-Connections; Primary evidence focus: Annex A.8 monitoring, network security, segregation, vulnerability, and supplier-egress evidence; Boundaries and complementary controls: Certification depends on ISMS design, SoA, risk treatment, internal audit, and management review; CSW is a technical evidence source

CISA Zero Trust Maturity Model: Customer scope anchor: Agency/enterprise zero-trust initiative by pillar and use case; Suggested CSW scope pattern: ZT-Workloads > Sensitive-Apps, Privileged-Admin, Inter-App-Flows, External-Dependencies; Primary evidence focus: Workload-layer evidence for networks and applications/workloads pillars, plus visibility and analytics; Boundaries and complementary controls: ZTMM maturity is organizational; pair CSW with IdP, MFA, device posture, data governance, SIEM/SOAR, and policy orchestration

FIPS 140: Customer scope anchor: Systems handling regulated cryptographic use or plaintext-protocol risk; Suggested CSW scope pattern: Crypto-Review > Sensitive-Transport, Plaintext-Protocol-Candidates, FIPS-Required-Systems; Primary evidence focus: Detection/blocking of obvious plaintext transports and inventory support for cryptographic usage review; Boundaries and complementary controls: CSW is not a FIPS-validated cryptographic module; validation, key management, and module selection belong to FIPS-validated libraries/HSMs

NIST SP 800-207: Customer scope anchor: Zero Trust Architecture tenets for workload-to-workload access; Suggested CSW scope pattern: ZTA-Resources > Protected-Resources, Policy-Enforced-Flows, Observed-Dependencies, Exceptions; Primary evidence focus: Resource inventory, per-connection flow evidence, dynamic scoping, workload enforcement as one possible PEP placement; Boundaries and complementary controls: NIST ZTA also requires identity, device posture, policy decision architecture, and enterprise-wide telemetry beyond CSW

NIST SP 800-207A: Customer scope anchor: PDP/PEP/PA/PIP component mapping for a cloud-native ZTA discussion; Suggested CSW scope pattern: ZTA-Components > PEP-Analogue, Policy-Workspace, Telemetry-PIP, SOAR-Integrated; Primary evidence focus: Illustrative traceability from CSW policy, enforcement, and telemetry to 207A-style logical components; Boundaries and complementary controls: Treat PDP/PEP/PA/PIP mapping as an analogue for workload segmentation, not a complete enterprise ZTA architecture

DORA: Customer scope anchor: Important business functions (IBFs), supporting ICT assets, and third-party dependencies; Suggested CSW scope pattern: DORA-IBF > one scope per IBF, with nested Critical, Supporting, Third-Party-Egress, Incident-Dossier scopes; Primary evidence focus: Article 8 inventory inputs, Article 9 segmentation, Article 10 detection, Article 19 incident evidence, Article 28 technical egress; Boundaries and complementary controls: DORA governance, register of information, contracts, testing programme, and authority reporting remain customer-owned

NIS2: Customer scope anchor: Essential/important entity services and Article 21 risk-management measures; Suggested CSW scope pattern: NIS2-Service > Essential-Service, Important-Service, Supplier-Egress, Incident-Reporting, High-Risk-Workloads; Primary evidence focus: Risk-policy enforcement evidence, incident dossier, supply-chain egress, vulnerability exposure, secured workload paths; Boundaries and complementary controls: MFA, training, governance, cryptography, secured voice/video, and national transposition specifics require complementary programmes

NERC CIP: Customer scope anchor: IT-side systems supporting BES Cyber System functions; Suggested CSW scope pattern: BES-Supporting-IT > EACMS, Jump-Hosts, Vendor-Access, BCSI-Hosts, Identity-PKI, Patch-Repo; Primary evidence focus: IT-side ESP boundary evidence, interactive remote access paths, ports/services baseline, vulnerability and change evidence; Boundaries and complementary controls: CSW is not an EAP and does not enforce on PLCs/RTUs/IEDs/HMIs; pair with boundary firewalls and OT-aware monitoring

TSA Pipeline Security Directive: Customer scope anchor: IT-side systems supporting Critical Cyber Systems and IT/OT segmentation; Suggested CSW scope pattern: Pipeline-IT-Estate > OT-Facing-IT, CCS-Supporting-IT, Vendor-Access, Patch-Repositories, Corporate-IT; Primary evidence focus: IT-side segmentation, documented IT-to-OT flows, access control, monitoring, unpatched-system risk evidence; Boundaries and complementary controls: CSW does not replace the Cybersecurity Coordinator, CAP/CIRP, architecture review, boundary firewall, or OT DPI/monitoring tools

CIS Controls v8.1: Customer scope anchor: Enterprise assets and software in the customer's Implementation Group scope; Suggested CSW scope pattern: CIS-IG2 > Enterprise-Assets, Software-Inventory, Secure-Config, Vuln-Exposure, Network-Monitoring; Primary evidence focus: Controls 1, 2, 4, 7, 8, 13, and 17 evidence for covered workloads; Boundaries and complementary controls: Reconcile CSW inventory with enterprise source of truth; endpoint, email, awareness, backup, and data controls are broader than CSW

NIST CSF 2.0: Customer scope anchor: CSF Profile outcomes, target tier, and management reporting needs; Suggested CSW scope pattern: CSF-Profile > Govern-Evidence, Identify-Assets, Protect-Segmentation, Detect-Monitoring, Respond-Dossier, Recover-Diff; Primary evidence focus: Technical evidence that feeds GV, ID, PR, DE, RS, and RC outcomes; Boundaries and complementary controls: CSF is an outcomes framework; CSW does not author the Profile or replace governance, risk appetite, or enterprise policy decisions

CMMC 2.0: Customer scope anchor: FCI/CUI enclave and CMMC assessment boundary; Suggested CSW scope pattern: CMMC-Scope > CUI-Enclave, FCI-Systems, CUI-Connected, Admin-Access, External-Services, Out-of-Scope-Validation; Primary evidence focus: AC, AU, CM, RA, SC, and SI technical evidence for CUI-scope workloads; Boundaries and complementary controls: CMMC requires SSP, POA&M, CUI scoping, and C3PAO/government assessment as applicable; CSW supports evidence but does not certify compliance

Label / Tag Recommendations

Baseline Labels for Every Customer

Use a small, consistent baseline across all frameworks. Keep values stable and controlled; avoid free-form spelling differences that split evidence.

Table: Label key / Example values / Why it matters

Label key: app; Example values: payments-api, ehr-core, identity; Why it matters: Groups workloads into application

scopes and ADM workspaces

Label key: env; Example values: prod, stage, dev, test; Why it matters: Separates production evidence from non-production noise

Label key: owner; Example values: team-payments, clinical-apps, platform; Why it matters: Connects policy exceptions and remediation to accountable teams

Label key: data_class; Example values: public, internal, confidential, phi, pci, cui; Why it matters: Drives regulated data boundaries and evidence queries

Label key: compliance; Example values: hipaa, pci, soc2, dora, cmmc, none; Why it matters: Enables framework-specific scopes without duplicating inventory

Label key: criticality; Example values: critical, high, medium, low; Why it matters: Supports prioritization, segmentation strictness, and incident response

Label key: internet_exposed; Example values: true, false; Why it matters: Helps identify boundary and attack-surface review candidates

Label key: third_party; Example values: none, supplier-name, processor-name; Why it matters: Supports supplier egress and business associate / processor reviews

Label key: region; Example values: us-east, eu-west, site-001; Why it matters: Supports residency, operational ownership, and sector/site reporting

Label key: lifecycle; Example values: active, exception, decommissioning; Why it matters: Keeps stale workloads and temporary exceptions visible

Framework-Specific Labels

Table: Framework / Additional label keys / Example values / Scope-design use

Framework: HIPAA; Additional label keys: phi_scope, clinical_system, baa_partner, ehr_app; Example values: in-scope, epic, clearinghouse-a, true; Scope-design use: Build ePHI and partner-egress scopes

Framework: SOC 2; Additional label keys: soc2_boundary, trust_service, system_component; Example values: in-scope, security, database; Scope-design use: Align workloads to the SOC 2 system description

Framework: PCI DSS v4.0; Additional label keys: pci_scope, cde_zone, card_data_role, qsa_exception; Example values: cde, cde-connected, pan-storage, none; Scope-design use: Separate CDE, connected, and out-of-scope validation populations

Framework: NIST 800-53; Additional label keys: system_id, impact_level, control_family, ssp_component; Example values: sys-001, moderate, ac, app-tier; Scope-design use: Tie workloads to SSP components and impact-level evidence

Framework: ISO 27001:2022; Additional label keys: isms_scope, soa_control, asset_type, supplier_related; Example values: in-scope, a.8.22, database, true; Scope-design use: Align CSW evidence with the SoA and asset inventory

Framework: CISA ZTMM; Additional label keys: zt_pillar, zt_stage_target, zt_use_case; Example values: networks, advanced, east-west; Scope-design use: Organize evidence by maturity pillar and use case

Framework: FIPS 140; Additional label keys: fips_required, crypto_review, plaintext_risk, module_owner; Example values: true, transport, high, platform; Scope-design use: Identify workloads needing crypto posture review

Framework: NIST 800-207; Additional label keys: zta_resource, pep_candidate, policy_source, access_pattern; Example values: protected, csf-workload, adm, inter-app; Scope-design use: Trace workload resources and enforcement patterns

Framework: NIST 800-207A; Additional label keys: zta_component, pdp_analogue, pip_signal, pa_workspace; Example values: pep, csf-policy, vuln-context, zta-prod; Scope-design use: Support logical-component discussion and traceability

Framework: DORA; Additional label keys: dora_ibf, ibf_name, ibf_criticality, ict_third_party; Example values: true, sepa-transfer, critical, provider-a; Scope-design use: Build IBF and third-party exposure scopes

Framework: NIS2; Additional label keys: nis2_entity_type, nis2_service, article21_measure, csirt_reportable; Example values: essential, health-service, 21-2-b, true; Scope-design use: Structure service, measure, and incident evidence

Framework: NERC CIP; Additional label keys: cip_scope, bes_support_role, eacms, bcsi, ot_facing; Example values: it-side, jump-host, true, false, true; Scope-design use: Isolate IT-side BES-supporting systems and access paths

Framework: TSA Pipeline; Additional label keys: tsa_scope, ccs_function, site, ot_facing, vendor_access; Example values: it-side, historian, site-001, true, true; Scope-design use: Build site-specific IT/OT and vendor access scopes

Framework: CIS Controls v8.1; Additional label keys: cis_control, implementation_group, asset_inventory_source; Example values: control-1, ig2, cmdb; Scope-design use: Organize evidence by Safeguard and Implementation Group

Framework: NIST CSF 2.0; Additional label keys: csf_function, csf_category, profile_scope, target_tier; Example values: protect, pr.ir, core-platform, tier-3; Scope-design use: Align evidence with CSF Profile outcomes

Framework: CMMC 2.0; Additional label keys: cmmc_level, cui_scope, fci_scope, assessment_boundary, poam_item; Example values: 12, in-scope, false, cui-enclave, poam-123; Scope-design use: Build CUI/FCI boundaries and C3PAO evidence sets

Workshop Output Checklist

By the end of a scope-design workshop, capture:

- ? The customer-owned authoritative inventory source and reconciliation owner.
- ? The CSW scope hierarchy for the selected framework.
- ? Required baseline labels and framework-specific labels.
- ? Initial values for regulated data, criticality, owner, and environment.
- ? Known gaps: unsupported workloads, missing connectors, uninstrumented OT,

unmanaged SaaS, IAM-only controls, physical controls, or legal obligations.

? The first ADM / flow-search window and evidence export cadence.

? A named owner for label hygiene and exception review.

Customer Conversation Prompt

The practical question is not "can CSW map to this framework?" It is:

Which workloads, flows, owners, and labels must be correct before the mapping becomes evidence a customer can validate with their assessor?

Use this guide to answer that question before building dashboards or collecting audit packets.